SECURITY WHITEPAPER · VERSION 2.1

بنية VEXORIS الأمنية والامتثال المؤسسي

ورقة بيضاء تقنية توضح الطبقات الدفاعية، آليات التشفير، ركائز المصادقة، ومعايير الامتثال المعتمدة في منظومة إدارة وتدقيق السجلات الطبية VEXORIS.

2025 | التصنيف: داخلي | إدارة السجلات الطبية | v2.1.0

محتويات الورقة

1 الملخص التنفيذي
2 الدفاع متعدد الطبقات
3 الركائز الأمنية الست
4 الامتثال والشهادات
5 الاستجابة للحوادث
6 الالتزام والإفصاح

SECTION · 01

الملخص التنفيذي

بُنيت منظومة VEXORIS على مبدأ "الأمان أولاً" (Security by Design)، وهو مبدأ يستوجب أن تكون كل طبقة تقنية في النظام مؤمّنة من مرحلة التصميم وليس كإضافة لاحقة. تتعامل المنظومة مع بيانات صحية حساسة، ولذلك تتبع أعلى المعايير الدولية في التشفير والتحكم في الوصول والمراقبة والامتثال.

تعتمد البنية على استراتيجية الدفاع المتعدد (Defense in Depth)، حيث لا يكفي اختراق طبقة واحدة للوصول إلى البيانات. سبع طبقات مستقلة من الحماية تعمل معاً، مدعومة بست ركائز تقنية وثماني شهادات امتثال دولية، ليصبح الوصول غير المصرح به إلى بيانات المرضى عملياً مستحيلاً.

SECTION · 02

الدفاع متعدد الطبقات

تتكون البنية الدفاعية من سبع طبقات مستقلة، كل منها يعمل كحصن منفصل. اختراق أي منها لا يمنح المهاجم وصولاً تلقائياً إلى الطبقات الأخرى.

01 **الهوية والتحقق**
MFA · FIDO2 · WebAuthn · SSO · Biometric

02 **محيط الشبكة**
NGFW · DDoS Mitigation · IDS/IPS · Segmentation

03 **حماية التطبيقات**
WAF · SAST/DAST · Secure SDLC · Dependency Scanning

04 **تشفير البيانات**
AES-256-GCM · TLS 1.3 · Argon2id · Confidential Computing

05 **التحكم في الوصول**
RBAC · ABAC · Least Privilege · JIT Access

06 **المراقبة والكشف**
SOC 24/7 · SIEM · AI Anomaly · Threat Intel

07 **الوعي البشري**
Security Training · Phishing Simulation · Awareness

SECTION · 03

الركائز الأمنية الست

إلى جانب الطبقات الدفاعية، ترتكز المنظومة على ست ركائز تقنية أساسية، كل منها مصمم لمواجهة فئة محددة من التهديدات:

- **التشفير المتقدم:** تشفير AES-256-GCM للبيانات المخزنة، TLS 1.3 للمنقولة، و Argon2id لكلمات المرور.
- **المصادقة المتعددة:** 2FA إلزامي، دعم FIDO2/WebAuthn، بصمة بيومترية، و SSO آمن.
- **التحكم في الوصول:** صلاحيات حسب الدور، مبدأ أقل صلاحية، ووصول مؤقت بموافقة (JIT).
- **المراقبة والكشف:** مركز عمليات أمني 24/7، SIEM، كشف الشذوذ بالذكاء الاصطناعي.
- **النسخ الاحتياطي:** RPO ≤ 15 دقيقة، RTO ≤ 60 دقيقة، نسخ جغرافية غير قابلة للتعديل.
- **الخصوصية والامتثال:** تقليل جمع البيانات، حق الحذف، إدارة الموافقات الصريحة.

SECTION · 04

الامتثال والشهادات الدولية

تعمل المنظومة وفق ثمانية أطر امتثال دولية معتمدة، تشمل أمن المعلومات، خصوصية المرضى، حماية البيانات، والاعتماد الصحي.

ISO 27001 أمن المعلومات	**HIPAA** بيانات المرضى	**GDPR** الخصوصية	**SOC 2** الثقة المؤسسية
ISO 27799 صحة رقمية	**PCI-DSS** المدفوعات	**NIST CSF** الأمن السيبراني	**CBAHI** اعتماد صحي

SECTION · 05

الاستجابة للحوادث

حتى مع أقوى الإجراءات الوقائية، تبقى الاستجابة السريعة والمنظمة ضرورة. تعتمد المنظومة على منهجية من خمس مراحل مع اتفاقيات مستوى خدمة (SLA) محددة:

- **الكشف (Detection):** أقل من 5 دقائق – عبر أنظمة المراقبة اللحظية.
- **الفرز (Triage):** أقل من 15 دقيقة – تصنيف الحادث وتحديد الخطورة.
- **الاحتواء (Containment):** أقل من 30 دقيقة – عزل الجزء المصاب.
- **الاستئصال (Eradication):** أقل من 4 ساعات – إزالة سبب الحادث.
- **التقرير (Report):** أقل من 48 ساعة – توثيق كامل للدرس المستفاد.

SECTION · 06

الالتزام والإفصاح

تلتزم إدارة السجلات الطبية بالإفصاح المسؤول عن أي حادث أمني يؤثر على بيانات المستخدمين، مع الالتزام بالإطار الزمني القانوني للإخطار (لا يتجاوز 72 ساعة في الحوادث عالية الخطورة). كما توفر المنظومة قناة إبلاغ مسؤولة عن الثغرات (Responsible Disclosure) عبر فريق الأمن الداخلي.

هذه الورقة مرجع تقني داخلي، ولا تُغني عن مراجعة سياسات الخصوصية وشروط الاستخدام الرسمية المنشورة على المنصة.